

TSEC Risk & Cyber Advisory LLC

Integrated Cybersecurity, Risk & Compliance Advisory

Resource 02

AI Risk Assessment Checklist

A Structured Method for Evaluating AI System Risk

NIST AI RMF 1.0 | NIST AI 600-1 | EU AI Act

Resource ID	TSEC-AI-02
Category	AI Governance
Framework Alignment	NIST AI RMF 1.0 (Map/Measure); NIST AI 600-1 GenAI Profile; EU AI Act risk tiers
Version	1.1
Published	July 2026
Intended Audience	Risk Managers, CISOs, Compliance Officers, AI/ML Engineering Leads
Prepared By	TSEC Risk & Cyber Advisory LLC
Classification	Public — For Educational & Advisory Use

TSEC Compliance Resource Library — www.tsecgrc.com/resources

Table of Contents

Table of Contents.....	2
Executive Summary	3
Risk Assessment Methodology	3
Step 1 — Establish Context (Map).....	3
Step 2 — Identify Risks Across the Five Domains (Map).....	3
Step 3 — Rate Likelihood and Impact (Measure)	3
Likelihood × Impact Scoring Matrix	4
Step 4 — Decide and Document (Manage)	4
Worked Example.....	5
Governance Risks.....	5
Security Risks	6
Privacy Risks	7
Compliance Risks	8
Key Jurisdictions to Consider	8
Third-Party Risks	9
Risk Summary.....	9
Roles & Responsibilities.....	9
Reassessment Triggers	10
Documentation & Audit Trail.....	10
Common Pitfalls.....	11
Next Steps	11
Glossary of Key Terms.....	11
About TSEC & Next Steps	12

Executive Summary

An AI risk assessment answers a narrower question than a general AI governance review: for this specific system, in this specific context, what could go wrong, how likely is it, and how severe would the impact be? Done well, it produces a documented, defensible basis for approving, restricting, or declining an AI use case — and it is now an explicit expectation under both regulatory frameworks (the EU AI Act's conformity assessment requirements for high-risk systems) and buyer-side due diligence (enterprise and financial-services customers increasingly require evidence of AI-specific risk assessment before signing).

This checklist provides a repeatable methodology and walks through five risk domains that should be evaluated for every AI system: governance risk, security risk, privacy risk, compliance risk, and third-party/vendor risk. It closes with a consolidated risk summary format, a worked example, and a scoring matrix that can be attached to an internal approval record or shared with customers and auditors as evidence of due diligence.

Risk Assessment Methodology

This assessment method follows the Map and Measure functions of the NIST AI Risk Management Framework: Map establishes what the system is and who it affects; Measure tests whether the risks identified during mapping are actually present and to what degree.

Step 1 — Establish Context (Map)

- Document the system's purpose, intended users, and deployment environment.
- Identify the type of system: predictive model, generative AI, autonomous agent, or an embedded feature inside a third-party SaaS product.
- Identify all data inputs, including any personal, health, financial, or otherwise sensitive data categories.
- Identify who is affected by the system's outputs and whether any decisions are "consequential" (affecting access to employment, credit, housing, healthcare, insurance, or government services).

Step 2 — Identify Risks Across the Five Domains (Map)

Work through each of the five domains in this document (Governance, Security, Privacy, Compliance, Third-Party) and record which risks apply to the system under review. Not every risk applies to every system — a low-sensitivity internal productivity tool will have a much shorter list than a customer-facing decisioning system.

Step 3 — Rate Likelihood and Impact (Measure)

- Rate each identified risk on likelihood (rare, possible, likely, near-certain) and impact (low, moderate, high, severe).

- Where feasible, test rather than estimate: run adversarial prompts against generative AI systems, evaluate model outputs for bias across demographic groups, and validate vendor security claims rather than accepting them at face value.
- Combine likelihood and impact into a single risk tier (Critical/High/Moderate/Low) using a consistent, documented scale.

Likelihood × Impact Scoring Matrix

Use this matrix as the default scoring method when a more sophisticated quantitative model is not yet in place. Plot each identified risk by likelihood (rows) and impact (columns) to derive its tier.

Likelihood \ Impact	Low	Moderate	High	Severe
Rare	Low	Low	Moderate	High
Possible	Low	Moderate	High	Critical
Likely	Moderate	High	Critical	Critical
Near-Certain	High	Critical	Critical	Critical

Step 4 — Decide and Document (Manage)

- For each Critical or High risk, document the specific control that mitigates it, who owns that control, and residual risk after mitigation.
- Route Critical-risk systems through a formal approval step involving legal, compliance, and executive sponsorship before production deployment.
- Set a review cadence proportional to risk tier — Critical and High systems should be reassessed at minimum annually or upon material change; Moderate and Low systems can follow a longer cycle.

Worked Example

To illustrate the methodology, consider a hypothetical mid-market healthcare SaaS company adding a generative AI feature that drafts responses to patient portal messages for staff review before sending.

Step 1 — Context

System type: generative AI (LLM-based drafting assistant), embedded in an existing patient portal vendor's platform. Data inputs: patient messages, which may include protected health information (PHI). Affected individuals: patients communicating with the practice. Consequential decision: no — a human reviews and sends every message, so the AI does not make the final decision, though a drafted response could still influence clinical communication if reviewed carelessly.

Step 2 — Risks Identified

- Governance: the feature was enabled by an office manager during a vendor software update, without going through IT or compliance review.
- Security: the vendor has not documented whether patient message content is used to improve its underlying model.
- Privacy: PHI is processed by a third-party AI feature without a clear Business Associate Agreement addendum covering AI processing specifically.
- Compliance: HIPAA's minimum-necessary standard and vendor accountability requirements apply; no AI-specific risk assessment has been performed.
- Third-Party: the vendor has not disclosed which underlying foundation model powers the drafting feature.

Step 3 — Rating

Likelihood of a privacy or compliance issue: Possible (the feature is in active use without safeguards). Impact: Severe (PHI exposure carries regulatory and reputational consequences). Using the scoring matrix, this combination rates as Critical.

Step 4 — Decision

Recommended action: suspend use of the drafting feature until the vendor provides a signed Business Associate Agreement addendum covering AI processing, confirms patient data is not used for model training, and IT/compliance completes a formal review. This is documented as a Critical finding with a 30-day remediation deadline and escalated to the executive sponsor.

Governance Risks

Governance risk covers the absence or weakness of the organizational structures needed to make and enforce good decisions about an AI system.

- ☐ No designated owner is accountable for this system's risk decisions.
- ☐ The system was deployed without going through a documented intake/approval process (a common finding for tools adopted informally by individual teams).
- ☐ No process exists to review the system when its underlying model, vendor, or configuration changes.
- ☐ Decision logic or model behavior cannot be explained in terms a business owner or auditor can understand.
- ☐ There is no plan for decommissioning the system or migrating away from it if the vendor or model is discontinued.

Security Risks

AI-specific security risk extends standard application security to threats unique to how models process instructions and data. The categories below reflect the OWASP Top 10 for LLM Applications and NIST AI 600-1's Information Security risk area.

Risk	Description	Assessment Question
Prompt Injection	Crafted input causes the model to follow attacker instructions embedded in data rather than the intended system prompt.	Can untrusted input (documents, web content, emails) reach the model without isolation from trusted instructions?
Sensitive Information Disclosure	The model reveals private data, credentials, or confidential content through its outputs.	Has the system been tested for leakage of training data, retrieved context, or system prompts?
Excessive Agency	An AI agent is granted more autonomy or system access than its task requires.	Can the agent take irreversible actions (send emails, execute transactions, modify records) without human confirmation?
Supply Chain / Model Integrity	Risk introduced through third-party models, plugins, or fine-tuning data of unknown provenance.	Is the source and integrity of the underlying model and any fine-tuning data documented and verifiable?
Data / Model Poisoning	Training or fine-tuning data is deliberately or accidentally corrupted, skewing model behavior.	Is the provenance of training and fine-tuning data controlled and auditable?
Improper Output Handling	Model output is passed downstream (into a database, a script, another system) without validation, enabling injection-style attacks.	Is AI output treated as untrusted input to any downstream system that consumes it?
Unbounded Consumption	Uncontrolled resource use (cost, compute, or API calls) triggered by malicious or runaway usage.	Are rate limits, cost controls, and usage monitoring in place?

Privacy Risks

Privacy risk assessment for AI systems should extend, not replace, the organization's existing privacy impact assessment process.

- ☐ Personal data is used to train, fine-tune, or provide context (RAG) to the model without a documented legal basis.
- ☐ Individuals are not informed that they are interacting with an AI system where disclosure is expected or required.
- ☐ The system makes or materially influences a decision about an individual without a clear path for human review or appeal.
- ☐ Data minimization is not applied — more personal data reaches the model than the task requires.
- ☐ Vendor terms permit use of submitted data (prompts, documents, customer data) to train the vendor's own models, without the organization's informed consent.

Compliance Risks

Compliance risk covers exposure to specific legal and regulatory obligations. The regulatory landscape for AI is moving quickly and unevenly across jurisdictions — this section should be treated as a starting checklist, not a substitute for legal review.

Key Jurisdictions to Consider

Jurisdiction / Framework	Relevant Trigger	Core Obligation
EU AI Act	System falls into Annex III high-risk categories (employment, credit, education, law enforcement, etc.)	Conformity assessment, technical documentation, EU database registration, human oversight
EU AI Act — Article 50	System interacts directly with individuals (chatbots) or generates synthetic content	Transparency: disclose that the individual is interacting with or viewing AI-generated content
U.S. State ADMT Laws (e.g., Colorado)	System makes or materially contributes to a "consequential decision" about an individual	Disclosure, consumer rights, and documentation requirements (specific obligations vary significantly by state and change frequently)
NYDFS Guidance	AI used in insurance underwriting or pricing by a regulated entity	Documented governance and non-discrimination review of AI-driven underwriting models
Financial Services AI Risk Guidance (e.g., U.S. Treasury framework)	AI used by a regulated financial institution, including via vendor	Independent testing, bias audits, hallucination measurement, vendor evidence verification

- ☐ The system falls into (or close to) the EU AI Act's high-risk category and lacks the required conformity documentation, human oversight, and registration.
- ☐ The system interacts with users without disclosing AI involvement, where transparency obligations would require disclosure.
- ☐ The system makes "consequential decisions" without the disclosure and human-review safeguards increasingly required under state automated-decision-making laws.
- ☐ Sector-specific obligations are not addressed — for example, NYDFS guidance on AI use in insurance underwriting and pricing, or model risk management expectations for regulated financial institutions.
- ☐ No legal or compliance sign-off is documented for systems operating in regulated domains.

A Note on the Regulatory Landscape

State and federal AI regulation is changing frequently — timelines, thresholds, and even entire statutory frameworks have shifted within the same year. Treat every compliance-risk finding as a prompt to confirm current obligations with legal counsel rather than relying on a fixed rule set.

Third-Party Risks

Most organizations encounter AI risk first through vendors — an embedded AI feature in an existing SaaS product, not a model the organization built itself. Third-party risk deserves its own line of assessment separate from the vendor’s general security posture.

- ☐ The vendor’s AI feature has not been separately assessed beyond the organization’s standard vendor security review.
- ☐ The vendor cannot document what happens to submitted data — whether it is used for model training, retained, or shared with sub-processors.
- ☐ The vendor cannot provide evidence of its own AI risk management practices (testing, bias evaluation, incident history) beyond a marketing claim.
- ☐ Contractual terms do not address AI-specific obligations: data use restrictions, model change notification, audit rights, and liability for AI-generated errors.
- ☐ The vendor relationship has not been tiered by criticality — not every AI vendor warrants the same depth of review, but critical ones (affecting credit, fraud, compliance, or customer communications decisions) require enhanced due diligence.

Risk Summary

Consolidate findings from all five domains into a single record for the system under review. This summary format is designed to be attached to an approval record, a customer security questionnaire response, or an internal risk register entry.

Domain	Highest Risk Identified	Risk Tier	Mitigating Control	Owner
Governance	[e.g., no designated system owner]	[Critical/High/Moderate/Low]	[control description]	[name/role]
Security	[e.g., prompt injection exposure]			
Privacy	[e.g., no consent basis for training data]			
Compliance	[e.g., missing AI disclosure to users]			
Third-Party	[e.g., vendor data-use terms undefined]			

Overall recommendation (approve / approve with conditions / decline / escalate):

Roles & Responsibilities

A risk assessment is only as good as the people accountable for acting on it. Assign each role below before beginning a new assessment cycle.

Role	Responsibility in the Assessment Process
Risk Assessor	Runs the assessment, documents findings across all five domains, proposes the initial risk tier.
System/Business Owner	Provides context on system purpose and use; implements approved mitigating controls.
Security Engineering	Validates security-domain findings through testing rather than self-reported claims.
Legal / Compliance	Reviews compliance-domain findings and confirms current regulatory obligations.
Executive Sponsor	Approves or escalates Critical-tier findings; signs off on residual risk acceptance.

Reassessment Triggers

A risk assessment reflects a system as it existed on the day it was performed. Certain events should trigger a new assessment regardless of the scheduled review cadence:

- The underlying model or foundation model provider changes (e.g., the vendor swaps to a new LLM version).
- The system is extended to a new use case, user population, or jurisdiction not covered by the original assessment.
- A security or privacy incident occurs involving the system, even if resolved without material harm.
- A new law, regulation, or regulatory guidance takes effect that plausibly applies to the system.
- The volume or sensitivity of data processed by the system materially increases.

Documentation & Audit Trail

A risk assessment that exists only as a verbal decision is difficult to defend later — to an auditor, a regulator, or the organization's own future self trying to remember why a system was approved. At minimum, retain the following for every assessed system:

- ☐ The completed risk summary (domain findings, tier, mitigating controls, and owner) for the current and prior review cycle.
- ☐ The identity of who performed the assessment and who approved the final decision.

- ☐ Any vendor evidence or documentation relied upon (security assessments, contract terms, certifications) as of the assessment date.
- ☐ A record of the specific regulatory triggers considered and the legal/compliance sign-off where applicable.
- ☐ The date of the next scheduled reassessment, and any interim reassessment triggers that apply to this system.

This record should be retrievable on short notice — during a customer security questionnaire, a cyber-insurance renewal, or a regulatory inquiry, the ability to produce a specific system’s assessment history quickly is itself evidence of a functioning program.

Common Pitfalls

1. Scoring likelihood and impact based on assumption rather than testing, especially for security risks that can be verified through adversarial prompt testing.
2. Assessing the AI feature in isolation from the vendor relationship that delivers it, missing third-party risk entirely.
3. Treating a completed risk assessment as a one-time gate rather than a living record that gets revisited when the system or its context changes.
4. Applying a Critical/High rating without documenting a specific mitigating control, which leaves the finding open-ended and difficult to close.

Next Steps

Once a system has been risk-assessed, remediation of Critical and High findings should be sequenced using TSEC’s AI Governance Roadmap, and any third-party findings should feed directly into a full AI Vendor Due Diligence review. Systems involving generative AI or LLM-based features specifically should also be evaluated against TSEC’s Generative AI Security Best Practices guide.

Glossary of Key Terms

Term	Definition
Conformity Assessment	The EU AI Act’s formal process for verifying a high-risk AI system meets required safety and governance standards before deployment.
Deployer	Under the EU AI Act, the organization using an AI system in the course of its business (as distinct from the "provider" who builds it).
Human-in-the-Loop	A control design requiring human review or confirmation before an AI-driven decision or action takes effect.

Term	Definition
Minimum Necessary Standard	A HIPAA principle requiring only the minimum PHI necessary be used or disclosed for a given purpose.
Residual Risk	The risk remaining after mitigating controls have been applied, requiring formal acceptance by an accountable owner.
Risk Tier	A categorization (e.g., Critical/High/Moderate/Low) combining likelihood and impact to determine required control depth.

About TSEC & Next Steps

TSEC Risk & Cyber Advisory LLC helps SMBs, SaaS companies, FinTech, healthcare organizations, professional services firms, manufacturers, and government contractors build governance, risk management, and compliance programs that hold up under audit — and under real-world adversarial conditions. Our advisory work spans SOC 2, ISO 27001, NIST CSF, HIPAA, PCI DSS, NYDFS, and emerging AI governance requirements.

This resource is one part of a broader compliance library. Organizations that need help translating a checklist into an operating program — policies, control ownership, evidence collection, board reporting, and audit readiness — typically engage TSEC for structured advisory support rather than building it alone.

Work With TSEC

Book a Strategy Call — a working session to review your current AI governance posture against NIST AI RMF and ISO/IEC 42001, and identify the highest-priority gaps.

Email: Info@tsecgrc.com

Web: www.tsecgrc.com

Visit www.tsecgrc.com/resources for the full compliance resource library

© 2026 TSEC Risk & Cyber Advisory LLC. This resource is provided for general informational and educational purposes and does not constitute legal advice. Organizations should consult qualified legal counsel to assess specific regulatory obligations.